

PRIVACY IMPLEMENTATION PLAN

Version 1.0

Revision Date: August 28, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Privacy Implementation Plan
Document ID	PLN-PRIV-001
Current Version	1.0
Approved Date	August 28, 2026
Approved By	Information Security Steering Committee
Effective Date	August 28, 2026
Next Review Date	August 28, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Quarterly while open, then annual
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Plan is authorized by the Privacy Policy (POL-PRIV-001) and sets out how the obligations that Policy states are put into operation and evidenced. The Privacy category of the Trust Services Criteria remains out of scope for the current examination; this Plan is what makes the category achievable when a client agreement requires it, without a restart.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 PURPOSE	5
2 SCOPE	5
3 ROLES AND RESPONSIBILITIES	5
4 CURRENT POSITION	5
5 WORKSTREAM 1 — PROCESSING INVENTORY.....	5
6 WORKSTREAM 2 — NOTICE, COOKIES AND CONSENT.....	6
7 WORKSTREAM 3 — DATA SUBJECT REQUESTS	6
8 WORKSTREAM 4 — SUB-PROCESSORS AND TRANSFERS.....	6
9 WORKSTREAM 5 — BREACH NOTIFICATION	7
10 WORKSTREAM 6 — AI PROCESSING POSITION	7
11 SEQUENCE AND MILESTONES	7
12 EVIDENCE PRODUCED	8
13 MEASURES	8
14 ASSUMPTIONS AND DEPENDENCIES.....	8
15 REFERENCE.....	9
16 DOCUMENT PLAN HISTORY	9

1 Purpose

The Privacy Policy states what the Company owes the people whose personal data it holds. This Plan says who does what about it, by when, and what artifact proves it was done. Nothing here creates a new obligation; it schedules the ones already carried.

The Plan is worked in order. A workstream that is complete stays in the document with its evidence named, because the next examination will ask when it was done and not whether it is still on a list.

2 Scope

Personal data the Company holds as controller — personnel, candidates, website visitors, enquirers and customer contacts — and personal data it processes as processor on behalf of clients. The Plan covers the systems that hold that data and the sub-processors that touch it.

3 Roles and Responsibilities

1. The Accountable Party owns the Plan, approves the scoping position, and accepts or rejects any workstream that closes without meeting its measure. [SOC 2: CC1.3]
2. The Security Officer runs the Plan day to day, holds the artifacts, and reports progress at each quarterly review while workstreams remain open. [SOC 2: CC1.3, CC4.2]
3. The Information Security Steering Committee receives the report, and its acceptance of a closed workstream is recorded in the same way as any other Committee decision. [SOC 2: CC1.2]
4. Where a workstream depends on external counsel — a transfer assessment, a controller/processor determination — the Accountable Party engages it and the advice is retained with the artifact. [SOC 2: CC1.3]

4 Current Position

1. The Privacy Policy and the published Privacy Notice exist and are aligned. The Notice carries the Article 13 and 14 disclosures. [GDPR Art. 13, 14]
2. The Privacy category of the Trust Services Criteria is out of scope by a recorded decision, revisited when a client agreement requires it or when the Company begins acting as controller for material volumes. [SOC 2: CC3.2]
3. The obligations are stated but the operating record behind several of them is thin: there is no completed processing inventory, no exercised data subject request procedure, and no tested breach notification path. That gap is what this Plan closes. [SOC 2: CC4.2]

5 Workstream 1 — Processing Inventory

1. Record each processing activity with its purpose, categories of data and data subjects, legal basis, systems involved, recipients, retention period and transfer position. [GDPR Art. 30 · Owner: Security Officer · Due: Q4 2026]

2. Reconcile the inventory against the sub-processor list and the asset inventory, so that a system holding personal data cannot be absent from one of the three. [SOC 2: CC2.1 • Owner: Security Officer • Due: Q4 2026]
3. Confirm for each activity whether the Company acts as controller or processor, and record the reasoning where it is not obvious. [GDPR Art. 28 • Owner: Accountable Party • Due: Q4 2026]
4. Set the inventory to be reviewed annually and on any significant change, and name the trigger in the Risk Management Policy that catches a new processing activity. [SOC 2: CC3.4 • Owner: Security Officer • Due: Q1 2027]

6 Workstream 2 — Notice, Cookies and Consent

1. Verify that the deployed cookie banner sets no non-essential cookie before consent, and record the test with a date and a browser trace. A banner that is present but ineffective is the common finding. [Owner: Security Officer • Due: Q4 2026]
2. Confirm the consent record retains what was consented to, when, and how it can be withdrawn, and that withdrawal takes effect. [GDPR Art. 7(1), 7(3) • Owner: Security Officer • Due: Q4 2026]
3. Verify that Global Privacy Control signals are honored, as the Notice states they are. [CPRA §1798.135 • Owner: Security Officer • Due: Q4 2026]
4. Put the Notice and the Policy on one review, so that a change to either forces a read of the other. [SOC 2: CC2.3 • Owner: Security Officer • Due: Q1 2027]

7 Workstream 3 — Data Subject Requests

1. Write the request procedure: intake at the published address, identity verification, the controller/processor routing decision, the response clock, and what is retained afterwards. [GDPR Art. 12, 15 • Owner: Security Officer • Due: Q4 2026]
2. Run one test request end to end and record the elapsed time against the statutory period. An untested procedure is a document, not a control. [SOC 2: CC2.3 • Owner: Security Officer • Due: Q1 2027]
3. Open the request register, even if it stays empty. An empty register with a start date is evidence; a missing one is not. [SOC 2: CC2.3 • Owner: Security Officer • Due: Q4 2026]
4. Confirm the client-facing path for requests that reach the Company as processor, and that the engagement agreements say the same thing the Notice does. [GDPR Art. 28(3)(e) • Owner: Accountable Party • Due: Q1 2027]

8 Workstream 4 — Sub-processors and Transfers

1. Complete the sub-processor list with what each processes, where it processes it, and the contract that binds it. [GDPR Art. 28 • Owner: Security Officer • Due: Q4 2026]
2. Confirm a data processing agreement is in place with every sub-processor that touches client personal data, and that each carries the Article 28(3) terms rather than a general confidentiality clause. [GDPR Art. 28(3) • Owner: Accountable Party • Due: Q1 2027]

3. Record the transfer mechanism for each provider outside the UK or EEA, and complete a transfer assessment where the mechanism is the Standard Contractual Clauses. [GDPR Art. 46 · Owner: Accountable Party · Due: Q1 2027]
4. Establish the client notification path for a new sub-processor, and the notice period the engagement agreements actually commit to. [GDPR Art. 28(2) · Owner: Security Officer · Due: Q1 2027]

9 Workstream 5 — Breach Notification

1. Extend the incident notification matrix to name the personal data case explicitly: who assesses risk to individuals, the 72-hour supervisory authority clock, and the processor duty to tell the controller without undue delay. [GDPR Art. 33 · Owner: Security Officer · Due: Q4 2026]
2. Add a personal data scenario to the annual incident exercise and record where the matrix was wrong. [SOC 2: CC7.4 · Owner: Security Officer · Due: Q2 2027]
3. Confirm the client contact of record for breach notification is current for every active engagement, and refresh it at the annual review. [SOC 2: CC2.3 · Owner: Security Officer · Due: Q1 2027]

10 Workstream 6 — AI Processing Position

1. Record, for each AI service used in delivery or internally, the terms under which submissions are excluded from provider training, and the configuration setting that gives effect to those terms. [SOC 2: CC9.2 · Owner: Security Officer · Due: Q4 2026]
2. Verify that setting rather than assuming it, and record the check. The statement in the Notice depends on this and on nothing else. [SOC 2: CC9.2 · Owner: Security Officer · Due: Q4 2026]
3. Confirm that no automated decision producing legal or similarly significant effects is made about an individual without a named person accountable for the output. [GDPR Art. 22 · Owner: Accountable Party · Due: Q1 2027]
4. Re-verify on any change of provider, plan or model, and add the check to the significant change trigger list. [SOC 2: CC3.4 · Owner: Security Officer · Due: Q2 2027]

11 Sequence and Milestones

The order matters. The inventory comes first because every later workstream refers to it, and the AI verification comes early because a public statement already depends on it.

1. Q4 2026 — Processing inventory drafted; cookie and consent behaviour tested; AI training exclusion verified; request register opened; notification matrix extended. [Owner: Security Officer]
2. Q1 2027 — Data processing agreements confirmed; transfer mechanisms and assessments recorded; request procedure exercised once; Notice and Policy placed on a joint review. [Owner: Accountable Party / Security Officer]
3. Q2 2027 — Personal data scenario run in the incident exercise; change triggers updated; Plan reviewed and either closed or reissued with the remaining items. [Owner: Security Officer]

4. The Plan is reported at each quarterly review while any workstream is open. A missed date is recorded with a reason and a new date rather than moved silently. [SOC 2: CC4.2]

12 Evidence Produced

1. The record of processing activities, with its review dates. [SOC 2: CC2.1 · GDPR Art. 30]
2. The cookie and consent test record, with dates and results. [SOC 2: CC2.3]
3. The data subject request procedure and register, and the test request result. [SOC 2: CC2.3]
4. The sub-processor list, the executed data processing agreements, and the transfer mechanisms and assessments. [SOC 2: CC9.2 · GDPR Art. 28, 46]
5. The extended notification matrix and the exercise record for the personal data scenario. [SOC 2: CC7.4]
6. The AI training exclusion verification, per service, with its date. [SOC 2: CC9.2]
7. The quarterly progress reports and the Committee acceptance of each closed workstream. [SOC 2: CC1.2, CC4.2]

13 Measures

1. Every processing activity in the inventory has a legal basis, a retention period and a named system. A blank is a finding, not a placeholder. [SOC 2: CC4.2]
2. Every sub-processor holding client personal data has an executed agreement carrying Article 28(3) terms. [GDPR Art. 28(3)]
3. A test data subject request completes within the statutory period, measured rather than estimated. [GDPR Art. 12(3)]
4. The AI training exclusion has been verified in the last twelve months for every service in use. [SOC 2: CC9.2]
5. No workstream is reported complete without its artifact in the repository. [SOC 2: CC4.2]

14 Assumptions and Dependencies

1. The Company continues to act as processor rather than controller for client personal data. If that changes, this Plan is reissued rather than extended. [GDPR Art. 28]
2. Dates assume the Security Officer engagement continues at its current cadence. A change in that cadence moves the dates, and the movement is recorded. [SOC 2: CC1.3]
3. Transfer assessments and any controller/processor determination that is genuinely contested depend on external counsel being available. [GDPR Art. 46]
4. Sub-processor terms depend on what the providers will agree to. Where a provider will not give Article 28(3) terms, the position is escalated to the Accountable Party rather than absorbed. [SOC 2: CC9.2]

15 Reference

1. POL-PRIV-001 Privacy Policy [SOC 2: CC2.3]
2. PromptHalo Technologies Privacy Notice [GDPR Art. 13, 14]
3. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
4. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
5. POL-IRP-001 Incident Response Policy [SOC 2: CC7.4]
6. POL-DRD-001 Data Retention, Disposal and Disaster Recovery Policy [SOC 2: CC6.5, A1.2]
7. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
8. SOC 2 Trust Services Criteria, Security category [CC1.2, CC1.3, CC2.1, CC2.3, CC3.2, CC3.4, CC4.2, CC7.4, CC9.2]
9. EU General Data Protection Regulation, Articles 7, 12, 13, 14, 15, 22, 28, 30, 33 and 46
10. California Consumer Privacy Act as amended by the CPRA, §§1798.100–1798.199

16 Document Plan History

Version	Date	Description
1.0	August 18, 2026	Initial release of the Privacy Implementation Plan.